

SignalBridge

Application access assurance: connect a permission change to an observed access result, an investigation and an accountable follow-up.

Prepared for Aman Agarwal | October 1, 2026. The enterprise milestone is in progress. This document groups the current implementation, recorded results, limitations and study checkpoints. It is AI-authored reference material, not an independent audit or assessment of your personal competency.

The business problem

A valid login does not mean a user still has permission to read a private record. When an employee or group member loses access, a security team needs evidence that the application enforces that change, a way to investigate unexpected access and a responsible person to verify the correction.

The intended enterprise workflow

Permission change → actual access observation → detection → investigation → assigned remediation → verified retest.

The current software adds durable source telemetry, safer queue processing, case ownership, five detection rules and two limited automation interfaces. Nine native PostgreSQL checks passed. The new 48-scenario evaluation preserves false alerts and misses; expanded native integrations and the full enterprise milestone remain unfinished.

Defensible today	Still required
1177 Python and 62 Node test methods passed in the retained offline round.	Native source execution, enterprise identity and the remaining current execution gates.
Historical native Wazuh delivery and finite anonymous ZAP pilots.	Continuous Wazuh, authenticated ZAP, genuine offline Shuffle and Keycloak MFA.
Native PostgreSQL concurrency/crash checks and a frozen 48-scenario evaluation.	Working separate restoration and the full 24-hour reliability run.

The deployment boundary is one enterprise with multiple application scopes. Production rollout, multiple customer tenants, high availability and broad endpoint/cloud coverage remain later milestones. No enterprise-tool replacement claim is established.

How the system fits together

Component	Responsibility and current boundary
Reference source applications	Private documents and expense records with four synthetic accounts. Database-backed authorization produces an outbox event in the same source transaction.
Source collector	Finite leases and stable event IDs survive interruption and lost replies. Prepared native transport accepts only the fixed TLS loopback destination and an explicit lab CA.
SignalBridge ingestion	Validate closed v1/v2 metadata and HMAC signatures; enforce credential-bound app, environment, source class and membership-assertion capability.
Detection workers	Process retained events and commit case evidence with completion. PostgreSQL queue claims use app-first locking and SKIP LOCKED; SQLite remains the single-worker lightweight profile.
Analyst console	Inspect source evidence, facts and uncertainty; assign work, acknowledge cases, set deadlines and record a disposition. A resolved review is not a verified security fix.
Optional lightweight use / required enterprise tools	Historical Wazuh and ZAP receipts exist. The expanded native tool, identity, monitoring and reliability gates are unfinished.

What a signature means

A valid signature shows that an accepted credential signed these bytes for this scope. It does not independently prove the source told the truth, that content reached a browser or that an attacker was malicious. Collector-assigned instrumented_lab provenance identifies the configured source class; a client cannot choose it.

Project and data boundaries

Work continues in signalbridge-public. The original SignalBridge, BetTail and Netted checkouts are preserved. Synthetic account/resource pseudonyms are app scoped. Telemetry excludes record bodies and credentials. The new reference service has not yet been launched as a native enterprise service.

What was actually checked

Each row below is an executed group from the current retained offline receipt. Passing test methods measure regression behavior; they do not measure detection accuracy, business savings or the fraction of an enterprise protected.

Check group	Executed result
Core application	1145 test methods; no failures or skips
Offline fault controls	3 test methods; no failures or skips
Reference applications and collector	29 test methods; no failures or skips
Django configuration	Passed
Main migration consistency	Passed
Source migration consistency	Passed
Python lint	Passed
Python formatting	Passed
Publication safety scan	Passed
Courier and file persistence	22 test methods; no failures or skips
HTTP harness (mock services)	17 test methods; no failures or skips
BetTail routes (mock services)	23 test methods; no failures or skips

Core and source-app tests use disposable SQLite. Source HTTP checks use Django's test client; collector and upstream transport replies are doubles. Node persistence tests exercise local files. None of these rows substitutes for a native PostgreSQL, TLS, SSO or security-tool execution.

This round retained separate raw logs, their hashes, a source manifest and before/after source checks. Source unchanged: True. Source files: 336. The recorded run used an uncommitted working tree; the source digest identifies that selected local content. Publication adds a Git commit without rewriting the execution receipt.

The courier imports its persistence tests, which run once in this profile. An earlier receipt executed those eight methods again; it remains preserved and is not evidence of 70 distinct Node methods. The September 1,102-test verification remains historical. New results do not overwrite earlier source identities.

From permission change to telemetry

A controlled access sequence

Step	Meaning
Allowed read	Authenticate the member and confirm the exact known synthetic private content.
Remove effective access	Change the grant and record its outbox assertion together. Owner rights or an alternate direct grant prevent a false revocation assertion.
Unchanged-session read	Keep the same valid session; confirm denial. A service failure is inconclusive, not evidence of correct authorization.
Owner control and restoration	The legitimate owner still reads the record. Restore the member and confirm the same known content again.
Bounded defect	Only the fixed document/member pair can receive the operator fault, for at most ten minutes. Reset and restoration checks are implemented.

Durable delivery

The outbox commits before network delivery. A collector releases SQL locks before IO, claims a 30-second lease, validates unchanged payload bytes, signs the request and requires an exact event acknowledgement. Lost replies retry the same logical ID. A stale lease cannot acknowledge another worker's record. Conflicts and modified records remain visible; transport failures receive bounded backoff.

Queue processing

The PostgreSQL design skips an app another worker owns, preserving per-app serialization while other apps progress. Completion timestamps, worker identity and retry state are persistent. Evidence writes and completion commit atomically. The native stage verified two workers, concurrent ingestion and recovery after an actual child-process SIGKILL during an uncommitted transaction.

Allowed reads load the latest relevant membership assertion rather than every read across 48 hours. Subject/resource/time indexes support that lookup. Retrospective correlation has a 10,000-event ceiling; exhaustion fails visibly. Committed attempt counters cannot count a process that dies before committing.

The next native source profile has a fixed HTTPS client, explicit certificate verification, secure-cookie checks and exact known-record predicates. Its driver resets the fixed defect and restores grants after failed checks. Twelve offline controls pass; the native recipe, controller and delivery reconciliation are still being prepared. No source service has been launched.

Accountable investigations

Console capability	How to use and interpret it
Business context	Read the app owner and asset criticality. Not assessed means missing business context, not low risk.
Ownership and acknowledgement	Assign a current app analyst/reviewer and acknowledge the initial review. First acknowledgement is recorded once; repeated acknowledgement cannot inflate that metric.
Work queues	Filter work assigned to you, unassigned, unacknowledged or overdue. Expanded rows show assignment, first acknowledgement and deadlines. Resolved cases are excluded from open-work queues.
Deadline and task	Set a bounded follow-up date. Create a review or remediation task tied to the retained case evidence. Open, In progress and Awaiting retest are work states.
Structured analyst notes	Separate observed facts, interpretation, uncertainty, remediation and verification notes. Earlier notes remain General rather than being automatically relabeled as facts.
Disposition versus remediation	Resolved records a completed review. The matching native retest and reviewer-controlled verified-fix transition are not implemented yet. A task or a verification note cannot substitute for them.

Two limited machine interfaces

Separate app-bound credentials can read case evidence or create a fixed review task. Requests sign the method, exact path, body, timestamp and nonce. Nonces prevent replay, and valid failed requests still consume replay/rate slots. The read response excludes analyst free text, is not cached, and has record/size limits.

Task creation checks the current case version and evidence digest. A stable idempotency key reconciles a lost reply without creating another logical task. Different content or targets conflict; later case changes reject stale retries. Native PostgreSQL verified concurrent duplicate requests, conflicting requests and one review task. Genuine Shuffle execution and enterprise TLS transport remain unfinished.

Browser writes retain session authentication and CSRF protection. Every write rechecks current app permissions. Automation cannot close cases, modify source accounts, send external messages or perform containment.

PostgreSQL verification

The final isolated stage used PostgreSQL 17.11 and Linux Python 3.14.7. All nine native test methods passed in 4.297 seconds; the whole stage took 22.917 seconds. Database readiness alone was never counted as a concurrency pass.

Latest internal stage: passed; 9 test methods executed. Acceptance passed: True.

Attempt	Observed result
Initial two attempts	Zero tests. Storage growth stopped the first; Windows-to-container connectivity failed the second. The first early watchdog receipt was missing; that defect was fixed and tested. Main shutdown passed.
First two internal attempts	Zero tests. An unquoted mount parsed into three entries, then the next run crossed the 8 GiB guard. Shutdown passed. The first detailed startup error was not retained; configuration validation was strengthened.
Dependency mounting / staging	Zero tests. Default noexec storage blocked the native driver; then installation exhausted scratch space. Separate kernel-verified mounts and installation staging inside the dependency area corrected these failures.
Final cached-package attempt	Nine passed; no failures, errors or skips. Duplicate/conflicting ingestion, two workers, case/task concurrency and killed-process recovery passed. Source was unchanged; main and independent shutdown passed.

Why the storage numbers need care

The image reports about 610 MiB, but host free space changed by more. Windows paging and other activity could contribute; comparable pre-stage measurements are incomplete. The conservative whole-stage guard includes prior consumption. Monitoring detects a crossing; it is not a hard storage quota.

The final approved guard was 12 GiB with at least 25 GiB free. The final receipt records about 70.0 GiB free. Containers and Docker Desktop were stopped; volumes, cached dependencies and receipts were retained. No cleanup of other projects was performed.

Executed isolation and limits

Two non-root containers received 512 MiB and one CPU each on an internal network: no published ports, runtime egress, host socket or other-project mounts. Read-only roots and removed capabilities remained. The runner verified noexec scratch and executable dependency storage in the Linux kernel. Six hash-verified cached wheels installed there with no host changes or new downloads.

This is plaintext PostgreSQL component proof at the retained revision. It does not verify enterprise TLS, the source HTTP service, identity, tools or the 24-hour profile. A later formatting correction preserves the tested migration's syntax tree; receipts retain their original exact source hashes.

Security tool integrations

Area	Recorded proof and remaining boundary
Wazuh manager 4.14.8	Historical native replay: 64/64 delivered events, 31 expected alerts and 33 expected non-alerts, no recorded loss/duplicates. A separate seven-input run recovered collector interruptions. Full dashboard/indexer, long-running rotation and new signal reconciliation remain unfinished.
OWASP ZAP 2.17	Historical finite passive profile made three anonymous fixture requests and returned five findings. An outage was retained as failed/incomplete, followed by a successful retry. Authenticated reference-app coverage, correction and equivalent retest remain unfinished.
Copied BetTail application	Historical native run: 23 route steps (16 assertions), 32 service steps (18 assertions). An unchanged valid session lost private state/image access; owner and restoration controls passed. The new v2 telemetry adapter remains unfinished; the original project is preserved.
Shuffle	No completed native workflow execution or task receipt. Retained VM storage/TLS failures remain. The new machine interfaces are building blocks, not a substitute or a mocked success.
Keycloak / Prometheus / Grafana	Not implemented or launched for this milestone. SSO/MFA/session lifecycle and operational observability remain required.

Delivery is separate from accuracy

64 of 64 events delivered measures transport reliability for that recorded workload. It does not measure detection recall or prove all enterprise activity is covered. The current minimal Wazuh export omits actor/resource context. Core detections forwarded later must be labeled SignalBridge signals, not independent Wazuh rediscovery.

How to present the evidence

Show the signed input, the native tool's retained result and the reconciliation. Explain why a failed ZAP run remains incomplete coverage. Explain that no Shuffle execution ID exists yet. The historical evidence viewer is useful for these narrow pilots; it does not establish that the expanded connectors are currently running.

Detection coverage and evaluation

Rule and version	Declared trigger and main limitation
R1 / rolling-v2	At least three distinct unsuccessful private reads by one actor in five minutes. Stale links can look identical.
R2 / source-revocation-v1	Allowed read labeled revocation/regression by its source. Depends on that source assertion.
R3 / resource-membership-v1	Latest authoritative effective removal before the subject's allowed read of the exact resource, within 24 hours. Missing assertions prevent inference.
R4 / bounded-denials-v1	Five distinct denied resources by one actor within 30 minutes, spanning at least ten minutes. Fixed case buckets; this is a bounded pattern, not an intent classifier.
R5 / bounded-denials-v1	Six denied reads of one resource by at least three accounts within ten minutes. Does not establish coordination; other resources do not combine.

The new frozen round used 48 builder-selected synthetic scenarios with signed in-process ingestion and the real worker. Labels were joined after predictions. The authors knew the rules; this is not an independent holdout or production benchmark.

Measure	Recorded result and denominator
Detections and misses	15 true positives and 8 false negatives / 23 suspicious scenarios.
False alerts and controls	6 false positives and 12 true negatives / 18 benign scenarios.
Precision / recall	15/21 = 71.4% / 15/23 = 65.2%.
False-positive rate / uncertainty	6/18 = 33.3%; 7 inconclusive scenarios excluded from binary scoring.
Analyst workload / delivery	24 initial review cases, 23 final active cases, 1 late correction. 181 requests / 174 logical events / 7 retries.

21 alerted scenarios produced 23 active cases because one scenario can match multiple rules. Initial work remains counted when late evidence corrects an alert. Q31's legitimate stale links remain a false positive; Q41's probing across different resources remains a miss.

The prior September 22-scenario results remain historical and use a different dataset. A formatting-only correction required a fresh freeze and repeat of the same 48 scenarios. Both receipts remain; repetition adds no independent statistical evidence.

Completion gates

Native PostgreSQL component checks and the bounded frozen detection round now have passing execution evidence. The enterprise milestone remains unfinished. Historical pilots and portable checks do not substitute for the required current native gates.

Area	Required finish
Access assurance	Native allowed → removed → denied → restored source sequences, owner controls and copied BetTail instrumentation.
Identity	Keycloak SSO/MFA, token rejection, logout, expiration, disabled accounts, current role withdrawal and reviewed TLS trust.
PostgreSQL — component passed	Nine native checks passed. Preserve that source identity and repeat affected checks after relevant implementation changes.
Wazuh / ZAP / Shuffle	Reconciled native collection; authenticated passive scan and equivalent retest; genuine offline workflow with one idempotent task.
Case workflow	Linked application/scanner/tool evidence and a matching retest with an independent reviewer decision before verified remediation.
Detection — bounded round passed	R4/R5 controls and 48 scenarios executed. Preserve misses, false alerts, uncertainty and distinct workload denominators; changed frozen code needs another round.
Operations	Prometheus/Grafana, a working separate restoration, full declared 24-hour run, reconciliation, latency and shutdown.
Presentation	Accessible console walkthrough, current actual integration evidence and an updated final handoff.

The full milestone retains its 10 GiB combined guest/container RAM planning ceiling, 30 GiB additional disk-growth ceiling and at least 25 GiB free. Revised launches, consequential downloads and machine/network changes receive an exact review. Paid services, public deployment, production credentials and autonomous response are outside scope.

The reliability target remains one event every four seconds per app across two apps for a completed 24 hours, plus eight declared bursts and interruptions. Target p95 ingestion below 500 ms and processing below five seconds outside interruption/recovery. No run or target is silently shortened to claim completion.

Your analyst and interview practice

What to do now

1. Read the business overview and architecture. Explain the difference between a valid login and current permission in your own words. 2. Trace one signed event into its case evidence. Identify the credential scope, event/result and uncertainty. 3. Write a fact, an interpretation and an uncertainty separately. 4. Choose an owner, a next action and evidence that would verify remediation. These are your learning exercises; they have not been submitted or independently assessed.

A precise investigation conclusion

If the removed member retains a valid session, receives HTTP 200 and the exact known private record, this establishes a read-boundary failure for that account, record, route and lab state. It does not establish write access, all-route exposure, attacker intent or a production breach. Verify the actual removal, alternate grants, timestamps, source provenance and owner control before escalation.

Explain an inconclusive result

A 503 response or the recorded PostgreSQL connection timeout cannot establish that a permission check worked. Preserve the failed attempt, diagnose the dependency or transport failure and repeat the equivalent check. Successful initialization is also different from executed concurrency tests.

Explain your AI-assisted contribution honestly

You directed the access-assurance goal, chose bounded review automation and required safety, evidence and honest reporting. AI wrote much of the implementation and reference material. Demonstrate ownership by explaining a rule, tracing its data, identifying a limitation and making or diagnosing a small change yourself. Do not claim independent authorship, an audit or a skill assessment that did not happen.

Likely recruiter questions

Why R3 rather than relying on R2? What is a false positive? Why are 64 delivered events not detection accuracy? How does idempotency handle a lost reply? Why preserve owner controls and alternate grants? What does verified remediation require? Which native gates are still unfinished? Answer with one retained example and its limitation.

Evidence and implementation map

These are repository-relative references. Public receipts contain sanitized summaries and hashes; raw logs and private credentials remain under ignored runtime paths. The original September source/evaluation and earlier recruiter PDF remain historical.

Location	Use
docs/evidence/ (current offline receipt)	Current offline execution summary, source digest and per-group log hashes; exact receipt named in docs/enterprise-milestone.json.
docs/evidence/ (PostgreSQL stage receipts)	Initial failures, later internal-network failures, nine-check pass, resource observations and shutdown proof. Diagnosis groups them without rewriting originals.
Milestone status	docs/enterprise-milestone.json groups gate status, approvals, limits and remaining work.
reference_lab/	Source authorization, effective grants, outbox, finite fault and TLS collector.
bridge/worker.py; bridge/case_workflow.py	Queue semantics, evidence binding and accountable human operations.
bridge/service_api.py	Limited machine capabilities, HMAC protocol, replay/rate checks and idempotent tasks.
integrations/enterprise/	Reviewed component recipes, pinned image/wheel identities and bounded in-network controls.
September evaluation	fixtures/detection_evaluation/ and portfolio/evaluation.html retain inputs, labels, freeze and metrics.
Enterprise evaluation	fixtures/enterprise_detection_evaluation/ retains both 48-scenario rounds. Current format2 receipt is named in the milestone status.

Current verification identity

a00935bc25a291726d7237789056453b311417e205bcd48980c52db279aed9b5

The digest identifies selected source files, not loaded-code attestation or protection from a local administrator. Documentation and generated artifacts are excluded from that source identity.

Resume point

Use the current stage receipts and explicit approvals for native work. Continue identity, source execution, verified case remediation, monitoring, genuine integrations, restoration and reliability. Preserve failed attempts. This handoff describes implementation in progress; it is not a finished enterprise certification.